Module 07: Perimeter Defence Evasion Techniques

```
# Exercise 07: Enumerating Firewall Access Control List and Bypassing WAF using Nmap
```

Scenario

Firewalls and Web Application Firewalls (WAF) inspect incoming packet structures, sizes, source ports, and hardware MAC vendor headers to enforce strict access control lists (ACLs). Security analysts and penetration testers evaluate firewall resiliency by executing specialized Nmap packet manipulation techniques designed to bypass inspection engines.

By applying packet fragmentation (**nmap -f certifiedhacker.com**), setting custom Maximum Transmission Units (**nmap -mtu 24 certifiedhacker.com**), spoofing trusted source service ports (**nmap --source-port 53 certifiedhacker.com**), and spoofing Ethernet MAC vendor headers (**nmap -sT -Pn --spoof-mac Dell certifiedhacker.com**), analysts evaluate how firewalls handle anomalous packet structures. Scanning the target domain **certifiedhacker.com** reveals its resolved IP address: **162.241.216.11**.

In this exercise, we execute SYN stealth and OS detection scans against **certifiedhacker.com**, resolve target IP **162.241.216.11**, perform port-specific probing, and apply packet fragmentation, MTU tuning, source port spoofing, and MAC address spoofing to enumerate ACL rules.

Objective

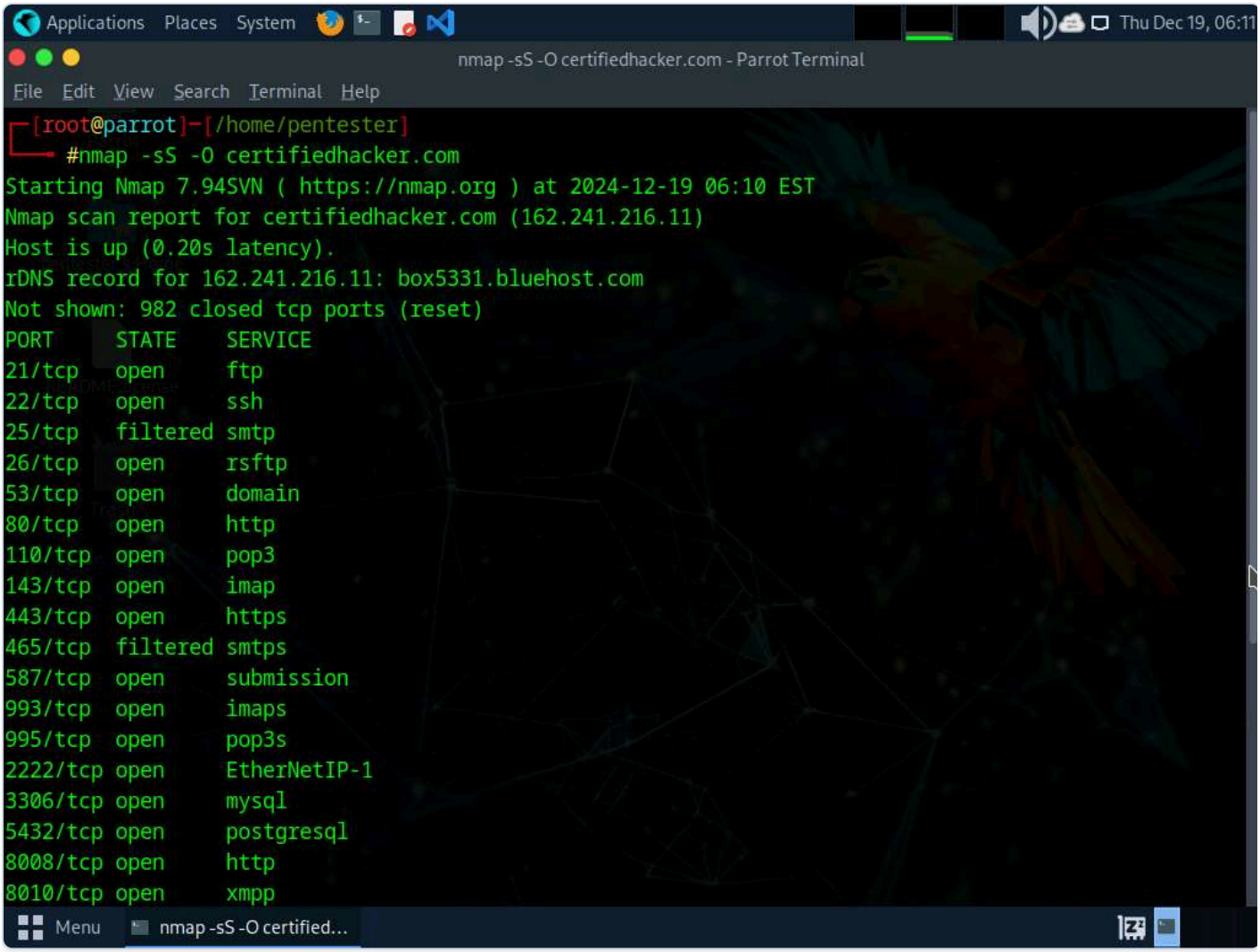
The objective of this lab is to help students learn how to:
- Perform TCP SYN stealth scans and OS identification using Nmap (**nmap -sS -O certifiedhacker.com**)
- Identify the public target IP address of **certifiedhacker.com** (**162.241.216.11**)
- Execute port-filtered Nmap scans (**nmap -sS -O certifiedhacker.com -p 80**)
- Evade packet inspection filters using IP packet fragmentation (**nmap -f certifiedhacker.com**)
- Configure custom packet MTU boundaries (**nmap -mtu 24 certifiedhacker.com**)
- Bypass ACL filtering rules using trusted source port spoofing (**nmap --source-port 53 certifiedhacker.com**)
- Execute MAC vendor hardware address spoofing (**nmap -sT -Pn --spoof-mac Dell certifiedhacker.com**)

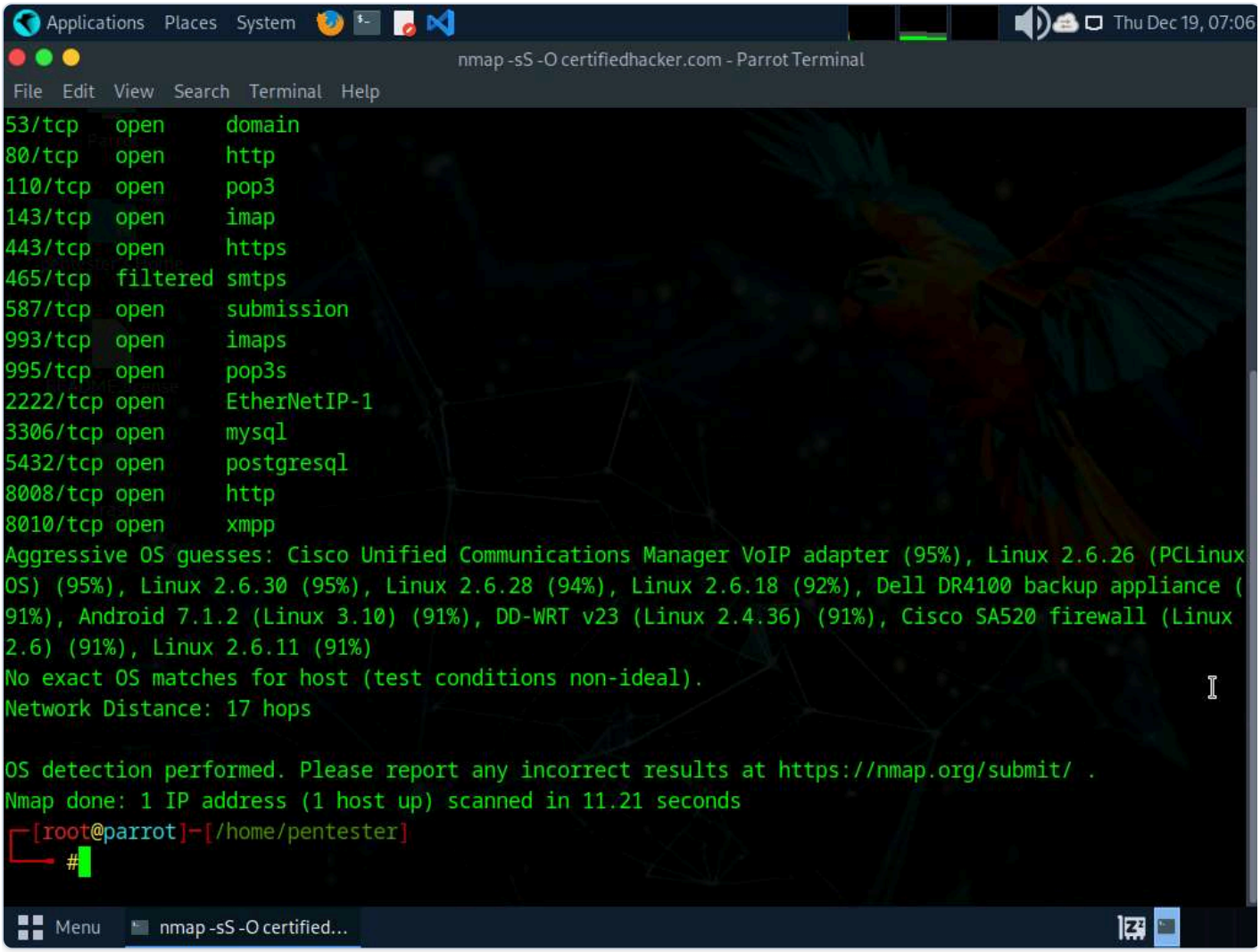
Task 1: Execute Nmap Evasion Scans against WAF and ACL Filters

In this task, we run SYN stealth scans against **certifiedhacker.com**, discover its resolved target IP (**162.241.216.11**), and apply various Nmap evasion switches (`-f`, `-mtu 24`, `--source-port 53`, `--spoof-mac Dell`).

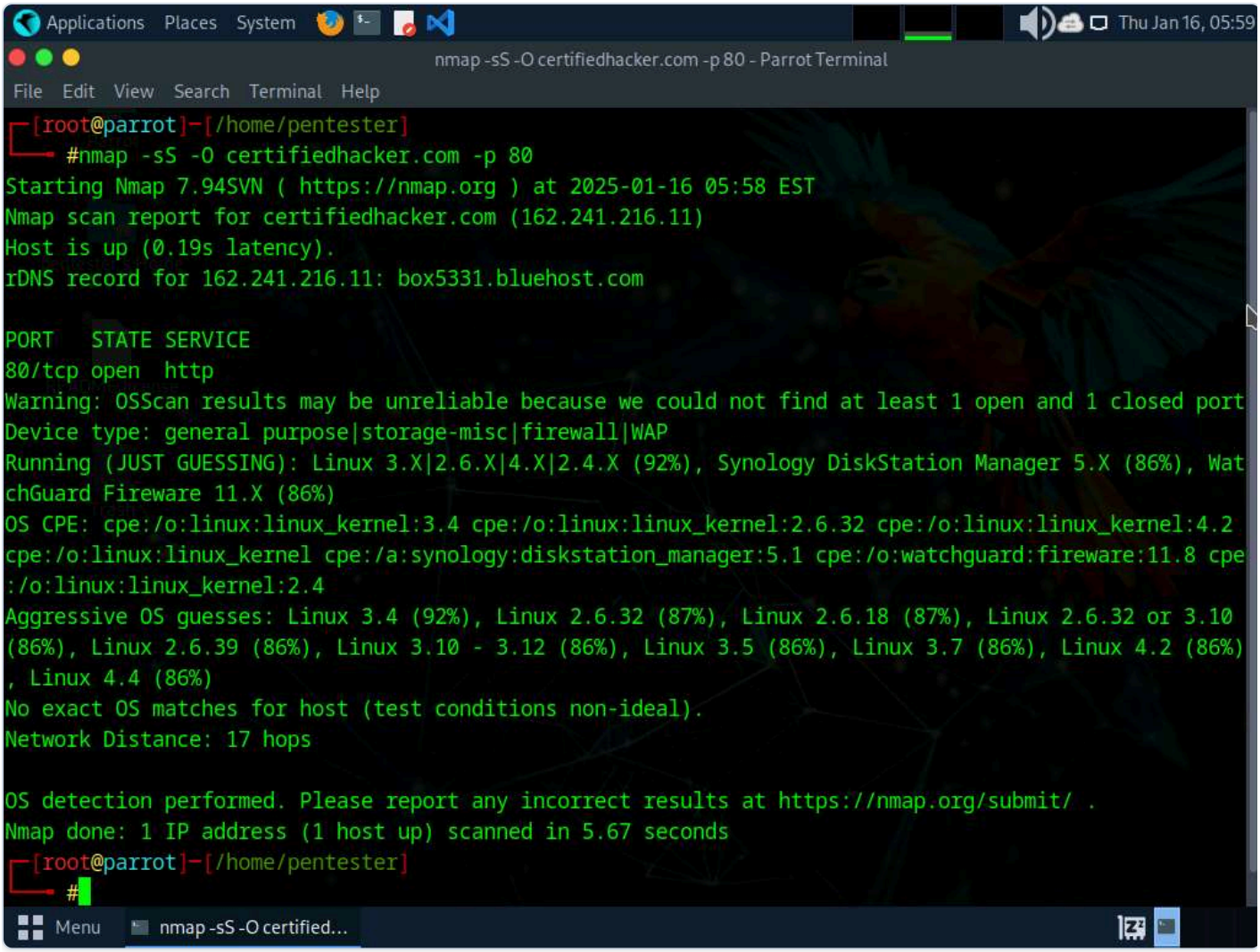
Lab Tasks

1. Switch to **Parrot Security** (**toor**). Open a terminal with sudo privileges and execute a SYN stealth scan with OS detection:
   nmap -sS -O certifiedhacker.com
   *Observe the scan output resolving **certifiedhacker.com** to IP address **162.241.216.11**.*

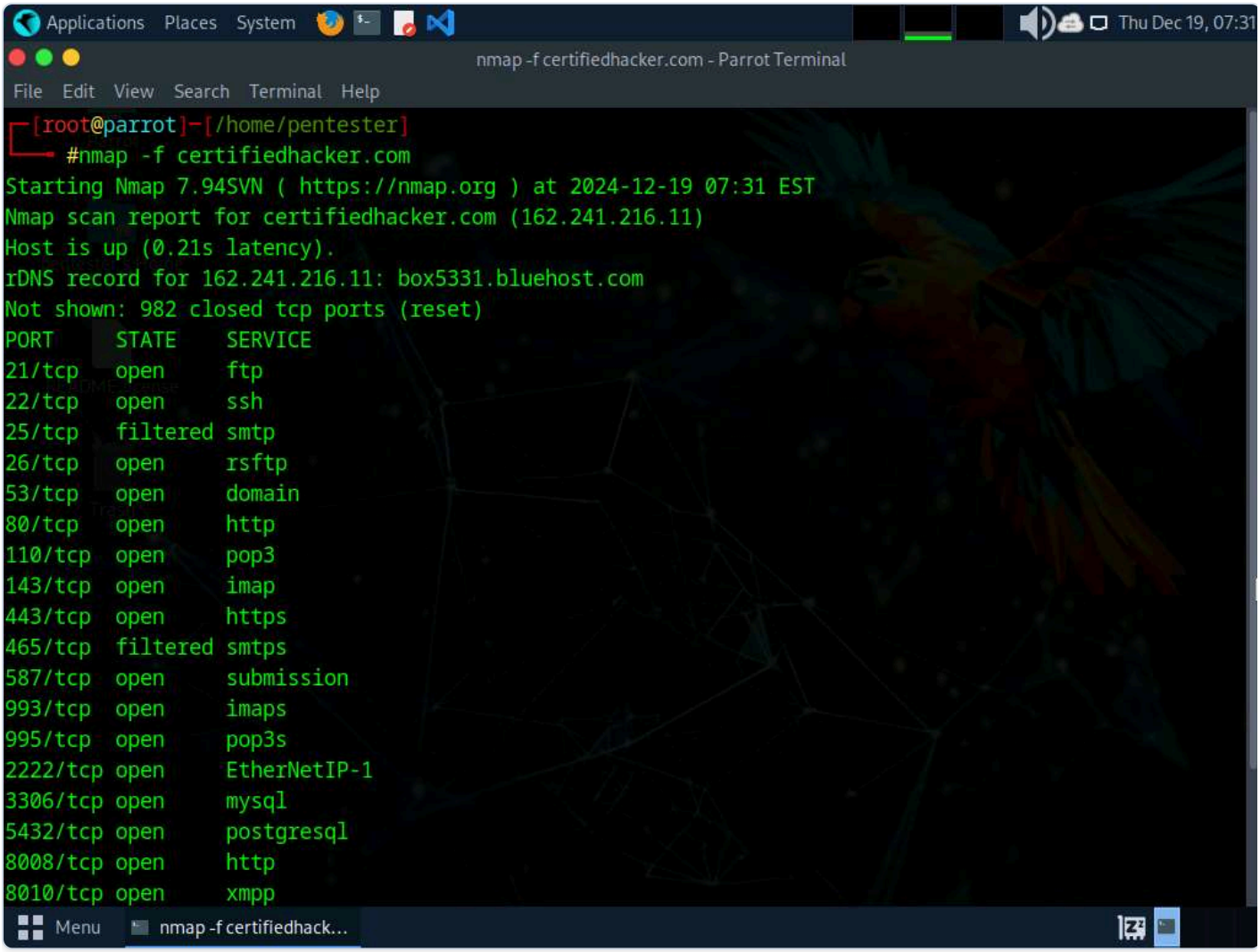

Applications Places System
Thu Dec 19, 06:11
nmap -sS -O certifiedhacker.com - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]-[/home/pentester]
#nmap -sS -O certifiedhacker.com
Starting Nmap 7.94SVN (https://nmap.org) at 2024-12-19 06:10 EST
Nmap scan report for certifiedhacker.com (162.241.216.11)
Host is up (0.20s latency).
rDNS record for 162.241.216.11: box5331.bluehost.com
Not shown: 982 closed tcp ports (reset)
PORT STATE SERVICE
21/tcp open ftp
22/tcp open ssh
25/tcp filtered smtp
26/tcp open rsftp
53/tcp open domain
80/tcp open http
110/tcp open pop3
143/tcp open imap
443/tcp open https
465/tcp filtered smtps
587/tcp open submission
993/tcp open imaps
995/tcp open pop3s
2222/tcp open EtherNetIP-1
3306/tcp open mysql
5432/tcp open postgresql
8008/tcp open http
8010/tcp open xmpp
Menu
nmap -sS -O certified...



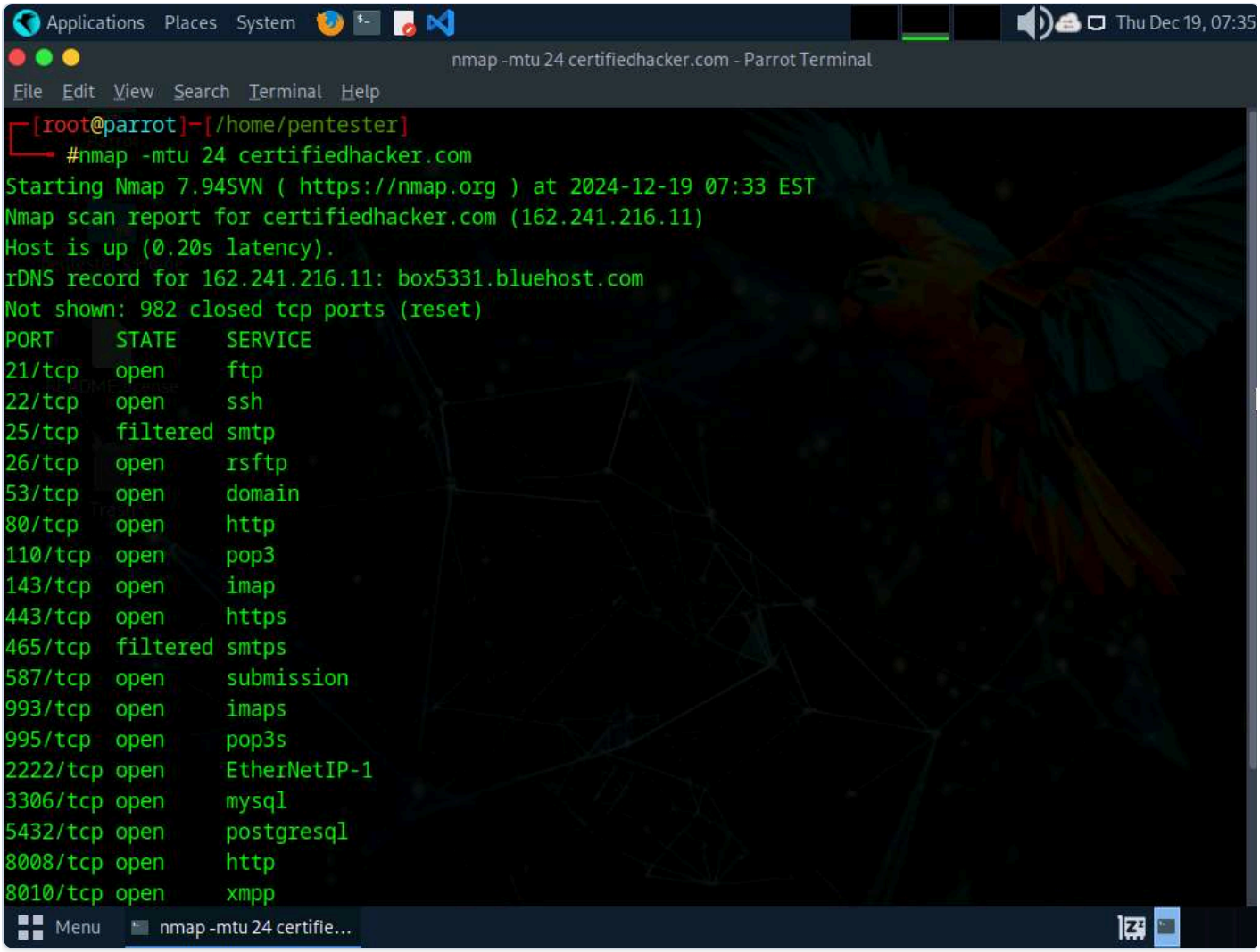
1. Perform a targeted scan on HTTP port 80:
   nmap -sS -O certifiedhacker.com -p 80



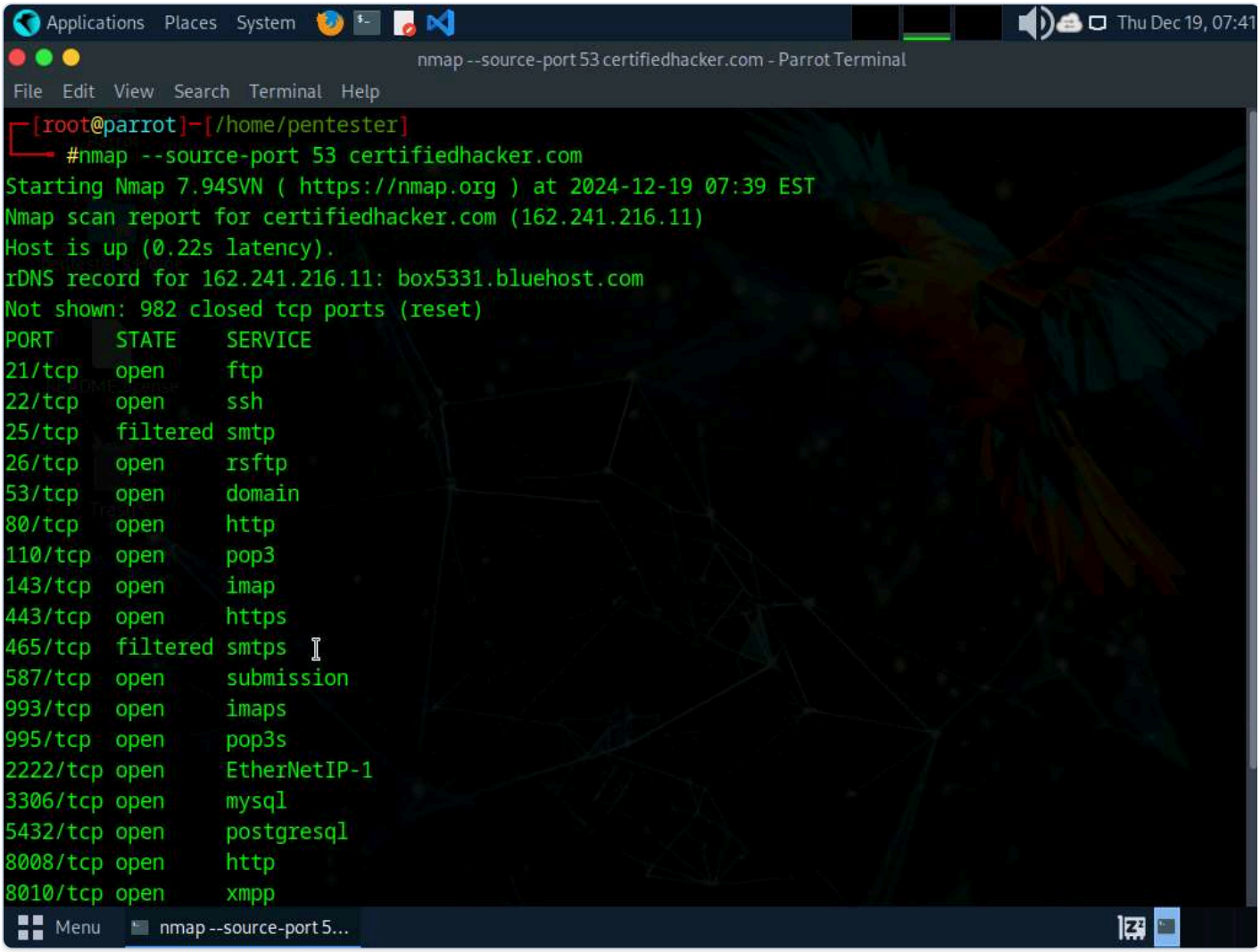
1. Execute packet fragmentation to bypass simple packet inspection rules:
   nmap -f certifiedhacker.com



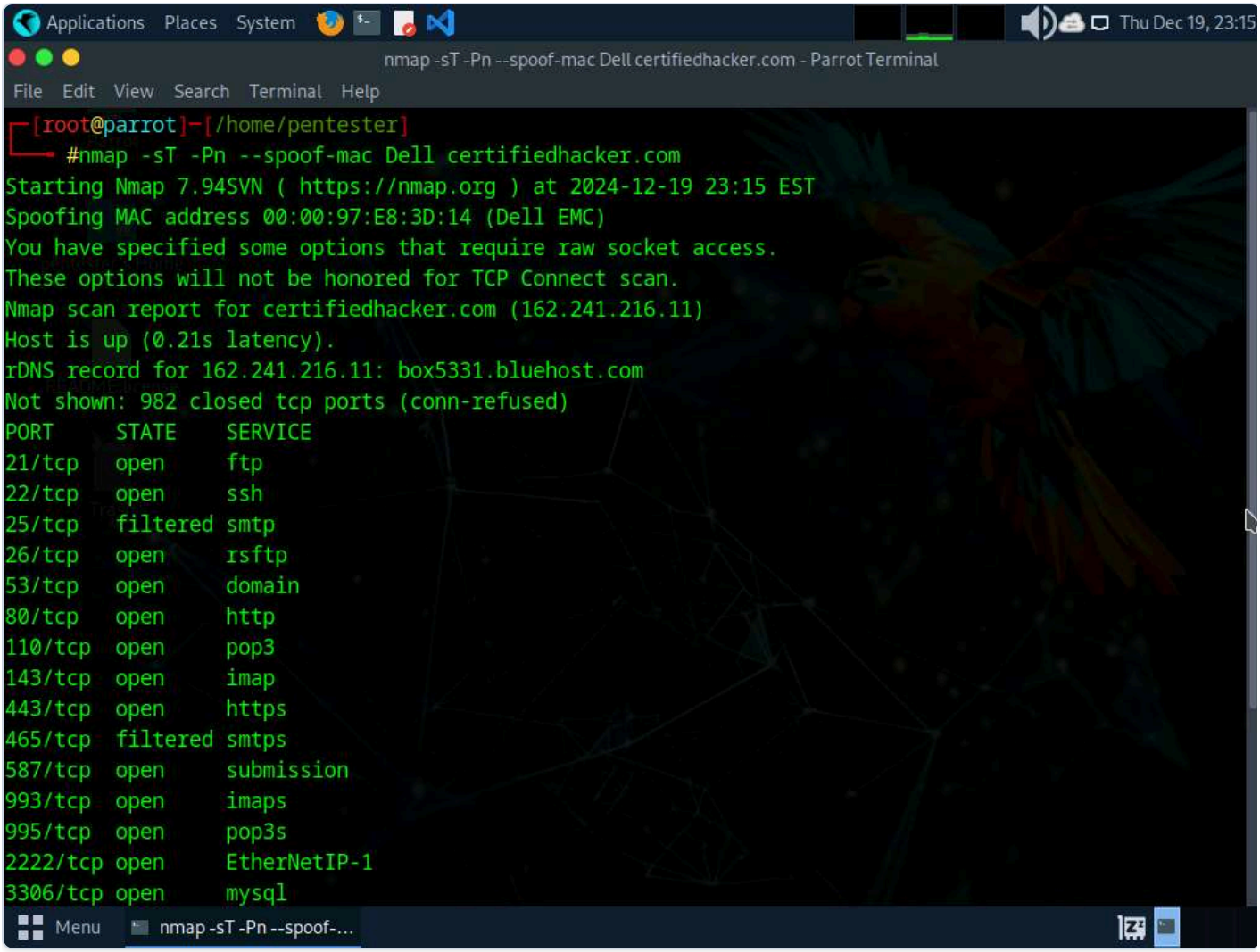
1. Execute packet fragmentation with a specific Maximum Transmission Unit (MTU) of 24 bytes:
   nmap -mtu 24 certifiedhacker.com



1. Bypass firewall ACL restrictions by spoofing source port 53 (DNS):
   nmap --source-port 53 certifiedhacker.com



1. Execute a TCP connect scan without host discovery, spoofing the MAC address of a Dell vendor device:
   nmap -sT -Pn --spoof-mac Dell certifiedhacker.com



1. Close all open terminal windows.

This concludes the lab exercise.

> **IMPORTANT:** ❓ **Question 7.7.1.1** On the Parrot Security machine, conduct Nmap scans to bypass web application firewalls (WAFs) and identify open ports and other relevant information associated with certifiedhacker.com. Identify the IP address of certifiedhacker.com for the scan. [!SUCCESS] ✅
> **Answer:** **162.241.216.11**